

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	• Over-privileged Access (lack of the principle of least privilege): the sales team was granted access to a parent folder containing sensitive 'internal-only' documents instead of just the specific promotions files they required. • Lack of Access Revocation: the manager failed to revoke the team's access to the internal folder immediately after the meeting concluded. • Poor Data Segregation: internal product plans and public promotional material were stored in the same digital vicinity as other non 'internal-only' documents, increasing the likelihood of human error

Review	● Principle of least privilege: AC-6 mandates that organisations employ the principle of least privilege, allowing only authorised access for users (or processes) which are necessary to accomplish assigned tasks. ● Restriction Of Privilege: it focuses on ensuring that users do not have more system privilege than they need, which limits the “blast radius” if an account is compromised or mistake is made”
Recommendation(s)	● Implement Role-Based Access Control (RBAC): Define access levels based on job roles; for example, Sales should only have "read" access to a specific "Public Assets" folder, with no access to "Internal Analytics". ● Use Link-Level Permissions: Instead of folder-level access, use "Specific People" sharing settings that expire automatically after a set time. ● Mandatory Access Reviews: Require managers to perform weekly audits of who has access to sensitive internal folders. ● Principle of Least Privilege (PoLP) and Separation of Duties (SoD): are core security controls. PoLP grants minimum necessary access to users/systems, limiting breach damage. SoD splits critical tasks among different individuals, creating checks and balances to prevent fraud and errors. Both are vital for strong cybersecurity and governance.
Justification	● Mitigates Human Error: By limiting the sales team's view to only relevant files, the system removes the possibility of a representative accidentally selecting a sensitive internal link. ● Enforces AC-6 Compliance: These improvements directly satisfy NIST AC-6 by ensuring users operate with the minimum privileges necessary, thereby protecting the confidentiality of non-public product analytics.

	• Strengthens Governance: <i>Regular reviews and SoD create a system of checks and balances that prevents "access creep," where employees slowly gain too much power over time.</i>
--	--

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.